直播脚本生成智能体安全漏洞修复说明

针对历史渗透测试问题的整改说明与验证结论

一、修复范围

本次修复覆盖历史安全测试中提出的弱口令、登录枚举、未授权访问、提示词注入等问题。

问题项	状态	修复摘要
4.1.2 用户弱口令	已修复	旧版本的登录页面和接口均为测试环境使用遗留，已删除相关前端页面和接口
4.1.3 用户名/密码枚举及暴力破解	已修复	旧版本的登录页面和接口均为测试环境使用遗留，已删除相关前端页面和接口
4.1.4/chat/api/dialogs 未授权访问	已修复	旧接口为测试使用遗留，已删除，新接口 /chat/api/conversations 全部要求 JWT，并按 token 归属校验。
4.1.5/chat/api/agent 未授权调用	已修复	旧接口为测试使用遗留，已删除，新接口 /chat/api/assistant 全部要求 JWT，并校验 dialogId 归属。
4.1.6 提示词注入	已加固	强化系统提示、角色边界、违禁词过滤和最终内容落库过滤。

二、漏洞修复情况

1. 用户弱口令问题/用户名枚举、密码枚举及暴力破解风险

原问题：历史版本存在 test001:123456、admin:123456 等弱口令，可被用于登录系统或进入后台。普通管理员曾拥有独立用户名和密码登录入口，存在弱口令和后台入口暴露风险。

修复措施：

- 删除普通管理员用户名/密码登录入口 /chat/login。
- 普通管理员不再拥有独立用户名和密码。
- 超级管理员创建管理员并绑定平台 userId。
- 非管理员用户不展示后台入口。
- 管理员 token、普通用户 token、超级管理员 token 均区分使用。

当前状态：已修复。

2 /chat/api/dialogs 未授权访问

原问题：历史接口未做鉴权，可通过枚举 userId 读取任意用户对话日志。

修复措施：

- 删除旧接口 /chat/api/dialogs。
- 新接口为 /chat/api/conversations，所有对话接口均要求 JWT 鉴权。
- 后端不再信任前端传入的 userId，用户身份统一从 JWT sub 字段获取。
- 查询对话、读取消息、删除对话、保存消息时均校验数据归属。

当前状态：已修复。

3. /chat/api/agent 未授权调用

原问题：历史接口未做鉴权，攻击者可直接发起智能体请求。

修复措施：

- 删除旧接口 /chat/api/agent。
- 新智能体接口为 /chat/api/assistant。
- 所有智能体接口均要求 JWT 鉴权。
- 后端不再使用请求中的 userId，身份统一从 JWT 中获取。

- 对话历史加载前校验当前用户是否拥有该 dialogId。

当前状态：已修复。

4. 提示词注入风险

原问题：大模型可能受用户输入中的提示词注入影响，出现绕过限制或输出不合规内容的风险。

修复措施：

- 强化系统提示词约束，禁止泄露系统提示、内部规则和安全策略。
- 对用户输入、文件内容和历史上下文进行角色边界隔离。
- 增加违禁词过滤机制。
- 流式输出结束后统一进行内容过滤，落库内容使用过滤后的最终内容。

当前状态：已修复。

三、接口验证结论

当前未发现历史高危未授权接口仍然可用。

```
GET  /chat/api/dialogs        => 404
POST /chat/api/dialogs        => 405
POST /chat/api/agent          => 405
```

核心业务接口无 token 访问均被拒绝：

```
/chat/api/conversations       => 403
/chat/api/assistant           => 403
/chat/api/memories            => 403
/chat/api/export              => 403
/chat/api/admin/*             => 403
```

四、总体结论

本次针对历史安全测试报告中的弱口令、暴力破解、用户枚举、未授权访问、提示词注入等问题已完成修复。

当前系统已经实现登录限流、失败锁定、统一错误提示、审计日志、JWT 鉴权、用户数据归属校验、旧危险接口删除和 token 有效期收紧。历史报告中的高危未授权访问问题已不再存在。